SUMMIT
INDUSTRIAL SERVICES

DOCUMENT **SIS-WEB-QA-01**
VERSION **1.1 · RETEST**
RETEST DATE **1 NOVEMBER 2026**
BUILD **RC-3 (125C4C8 + QA FIXES)**

QUALITY ASSURANCE · PUBLIC WEBSITE, CMS ADMIN AND API

QA TEST REPORT

Retest edition. All 21 findings from the v1.0 test cycle have been fixed and verified. This report records each fix, the retest evidence and the full regression results.

RELEASE RECOMMENDATION

Ready for production release from a QA standpoint. All 3 High, 7 Medium, 7 Low and 4 Info findings are closed and verified, and the full regression suite passes (200 of 200). Launch still depends on non-QA items: business-owner content sign-off and production hosting set-up (section 09).

200	200	21	0	2
Test cases in retest	Passed (100%)	Findings fixed and verified	Open defects	New informational notes

SYSTEM UNDER TEST	ENVIRONMENT	PREPARED BY	STATUS
Summit Industrial Services website + Summit CMS	Production build (SvelteKit / Node) · .NET 10 API · staging database	QA, website development team UBuck Nepal	All defects closed · retest passed

00 CONTENTS

01 Retest summary 3
02 Scope, approach and environment 4
03 Results summary 5
04 Defect register and resolutions 6
05 High defects: finding, fix, retest 8
06 Medium defects: finding, fix, retest 10
07 Low and Info: fix and retest 12
08 Detailed retest results 13
09 Client deliverables, test data and deployment notes 15
10 Evidence: screenshots 16
11 Document history 17

Severity definitions

HIGH	Security weakness or defect that can cause significant harm. Must be fixed before release.
MEDIUM	Defect with a real but limited impact, or a missing production control.
LOW	Minor defect, hardening or quality improvement.
INFO	Observation or recommendation; no defect in current behaviour.

Status key

FIXED	Code changed; the original failing test and new regression tests pass on the release-candidate build.
PASS / FAIL	Result of an individual test case in this retest.

01 RETEST SUMMARY

Version 1.0 of this report (1 November 2026) recorded 21 findings and recommended against release. Every finding has been fixed in the codebase. The full test suite was then re-run on a fresh production build: the original 144 cases plus 56 new regression cases written specifically for the fixes. All 200 passed.

ID	SEVERITY	FINDING (V1.0)	FIX (V1.1)	STATUS
QA-01	HIGH	Admin could escalate to SuperAdmin	Privilege guard on every user and role change; last-SuperAdmin and self-protection rules	FIXED
QA-02	HIGH	HTML/SVG uploads served as live pages	Content-based file-type allowlist; uploads served only as image/PDF, sandboxed	FIXED
QA-03	HIGH	Staging indexable in container deploys	Indexing decided from the real request host; `APP_URL` separated from the site URL	FIXED
QA-04	MEDIUM	Global login limit; no lockout	Per-IP limit plus per-account lockout (5 failures → 15 min)	FIXED
QA-05	MEDIUM	No password policy	12+ characters, common and simple passwords rejected, email name not allowed	FIXED
QA-06	MEDIUM	Contact page raw HTML title wrong	Competing fallback title removed from the root layout	FIXED
QA-07	MEDIUM	No security headers	CSP with nonces, frame-ancestors none, X-Frame-Options, nosniff, Referrer-Policy, Permissions-Policy, HSTS	FIXED
QA-08	MEDIUM	Audit gaps	Identity and sign-in events plus 14 hand-written endpoints now audited, with the real client IP	FIXED
QA-09	MEDIUM	CSV formula injection	CsvHelper formula escaping enabled	FIXED
QA-10	MEDIUM	HTTP 500 on invalid input	Global error handler and field validation for blog and work scopes	FIXED
QA-11 – 21	LOW / INFO	Token revocation, URL scheme, deletes, admin a11y, dependency, code quality, async email, labels, contrast, IP trust, history	All fixed; see section 07	FIXED

> **Correction to v1.0 (QA-08):** v1.0 stated that capability, industry, company and settings edits produced no audit entries. Code review during the fix showed those areas were already audited through the shared CRUD helper. v1.0 had only searched for direct audit calls. The real gaps were identity and security events and 14 hand-written endpoints, all now covered. The severity is unchanged.

New observations (Info, no action required for release)

- **QA-22:** audit-log filter tabs (Created, Updated, Deleted, Security) filter the current page of 25 entries, not the whole log, so a filtered page may show few rows. This behaviour predates this cycle. Recommendation: move filtering to the API in a future release.
- **QA-23:** page history keeps every saved version, with no way to delete one. The QA edit-and-rollback tests left five unpublished "QA-TEST" versions in the Contact page history; the original version is live. Recommendation: accept, or

add version pruning later.

02 SCOPE, APPROACH AND ENVIRONMENT

The scope is unchanged from v1.0: public website (10 page types and 404s), all 14 CMS admin screens, the REST API, the codebase and the deployment configuration. The retest re-ran every v1.0 case and added targeted regression cases for each fix.

SUITE	WHAT IT COVERS	CASES
API retest (Python)	Authentication, lockout and per-IP limits, authorisation matrix including real Admin-role escalation attempts, password policy, token revocation, validation, injection, uploads, external media, CRUD, audit trail, API headers, deletion and clean-up	110
Admin UI retest (Playwright)	Access control, clickjacking, login and session, 14 screens at 1440 and 390 px with axe, workflows: page edit/rollback/history, media upload/delete and refusal, enquiries and CSV, user and role create/delete, audit Security tab, keyboard	46
Public regression (Playwright + curl)	WCAG 2.2 AA in light and dark themes, layout at 4 widths, touch targets, keyboard, reduced motion, links, filters, FAQ, 404s, forms, email, rate limit, titles, indexing scenarios, CSP, headers, performance	36
Code and dependencies	Unit tests (61), type check, ESLint, Prettier, npm and NuGet vulnerability audits, build, JSON-LD escaping	8
Total		**200**

Tools

Playwright 1.48 with Chromium; axe-core 4.10 (WCAG 2.0/2.1/2.2 A and AA, run after animations settle); Python `requests`; xUnit and FluentAssertions; svelte-check; ESLint; Prettier; `npm audit`; `dotnet list package --vulnerable`.

With the new Content Security Policy in force, inline script injection is blocked. The test tools therefore inject axe-core through the browser's DevTools protocol, which also confirms the CSP works in practice.

Environment

Build	Branch `client-review-2026`, commit `125c4c8` plus the QA fixes (release candidate 3); frontend production build
Backend	SummitCms.Api (.NET 10), staging PostgreSQL database
Deployment simulation	Production and staging configurations reproduced with `ORIGIN`, `PUBLIC_SITE_URL` and Host headers, as the Coolify proxy will send them
Test data	All test records were prefixed QA-TEST and removed through the application's own delete functions (see section 09)

03 RESULTS SUMMARY

TEST AREA	V1.0 CASES	V1.0 PASS	V1.1 CASES	V1.1 PASS	V1.1 PASS RATE
API: authentication and session	14	12	24	24	
API: authorisation and privilege	8	8	17	17	
API: admin endpoints, CRUD and deletion	21	21	25	25	
API: validation, injection, robustness, XSS	15	14	18	18	
API: media and uploads	8	5	13	13	
API: audit trail and platform headers	-	-	13	13	
Admin UI (access, login, screens, workflows, a11y)	30	29	46	46	
Public site regression	35	32	36	36	
Code, dependencies, security review	13	7	8	8	
Total	**144**	**128**	**200**	**200**	

v1.0 code-review items (privilege escalation, security headers, CSV export) are now retested dynamically in the API and admin suites rather than by review alone.

0
WCAG AA violations: public site (light and dark) and all 14 admin screens

0
Open defects (21 fixed)

158 ms
Enquiry response time (was ~7.5 s); email sent in background

61 / 61
Backend unit tests (was 7)

0
Vulnerable runtime dependencies (npm and NuGet)

0 / 0
Type-check errors / warnings (was 13 warnings)

0
ESLint problems; Prettier clean (was 4 errors, 54 files)

0
CSP violations across public and admin pages

04 DEFECT REGISTER AND RESOLUTIONS

ID	SEV.	TITLE	RESOLUTION	STATUS
QA-01	HIGH	Admin role could escalate to SuperAdmin, reset or deactivate any account	New `IdentityAccessGuard` enforced in every user and role command; last-SuperAdmin and self-protection	FIXED
QA-02	HIGH	Any file type accepted; HTML/SVG served as active content	`MediaFileInspector` checks the file's contents (JPEG/PNG/GIF/WebP/AVIF/PDF, 15 MB); files stored under their real extension; `/uploads` serves only those types, with a sandbox CSP	FIXED
QA-03	HIGH	Staging noindex ineffective in container deployment	Indexability decided in the hooks file from the real Host or X-Forwarded-Host header and shared with robots.txt, the meta tag and the header; compose separates `APP_URL` (ORIGIN) from `SITE_URL`	FIXED
QA-04	MEDIUM	Global login rate limit; no lockout	Per-IP "auth" limiter (10/min); `LoginThrottle` locks an email for 15 min after 5 failures; visitor IP forwarded on every API call	FIXED
QA-05	MEDIUM	No password policy	`PasswordPolicy` (12–128 characters, not common, not trivially simple, not the email name) on create and reset; admin form hints and `minlength`	FIXED
QA-06	MEDIUM	Contact page raw HTML title showed fallback	Fallback `<title>` removed from the root layout; every route has exactly one title	FIXED
QA-07	MEDIUM	Security headers missing	SvelteKit CSP (nonce-based script-src, frame-ancestors none, object-src none); hooks add X-Frame-Options, nosniff, Referrer-Policy, Permissions-Policy, COOP, HSTS over HTTPS; API adds nosniff/DENY/no-referrer and hides the Server header	FIXED
QA-08	MEDIUM	Audit trail omitted security events	Identity events (users, roles, permissions, passwords, sign-in success, failure and lockout); `.WithAudit()` filter on 14 endpoints; real client IP via trusted forwarded headers; Security tab in the UI	FIXED
QA-09	MEDIUM	CSV formula injection	CsvHelper `InjectionOptions.Escape`	FIXED
QA-10	MEDIUM	HTTP 500 on invalid admin payloads	`ApiExceptionHandler` (400/409 for bad input, generic 500 with no internals); `InputValidation` for blog posts and work scopes	FIXED
QA-11	LOW	Deactivated user's token kept working	Active check on every authenticated request (15 s cache, cleared immediately on change); sessions revoked on deactivate, delete and password reset	FIXED
QA-12	LOW	External media accepted `javascript:`	Only absolute https URLs accepted (API and form)	FIXED
QA-13	LOW	Users and roles could not be deleted	DELETE endpoints plus admin UI with confirmation; built-in roles and assigned roles protected	FIXED

ID	SEV.	TITLE	RESOLUTION	STATUS
QA-14	LOW	Admin accessibility issues	Contrast tokens (faint text, strong accent, accent text); audit rows use a labelled toggle button; login error has `role="alert"`	FIXED
QA-15	LOW	Vulnerable Microsoft.OpenApi 2.0.0	Microsoft.AspNetCore.OpenApi 10.0.11 → Microsoft.OpenApi 2.7.5; 0 vulnerable packages	FIXED
QA-16	LOW	Lint, type-check and format issues	Unused code removed; reactive `$derived` data; JSON-LD lint documented; Prettier applied; 0 / 0 / 0	FIXED
QA-17	LOW	Enquiry email sent synchronously	`EnquiryEmailQueue` and background worker; enquiry saved first, email sent after the response	FIXED
QA-18	INFO	Admin said "Projects"	Admin navigation, headings, buttons, dashboard and permission group read "Work scopes"	FIXED
QA-19	INFO	Transition subline contrast in dark theme	Theme-aware `--gold-on-ink` token (5.1:1 or more on light backgrounds)	FIXED
QA-20	INFO	API trusted any X-Forwarded-For	ASP.NET forwarded-headers middleware trusts the header only from loopback and private networks	FIXED
QA-21	INFO	Page history lacked change summary	Versions API and history screen show each version's title and the fields changed from the previous version	FIXED
QA-22	INFO	Audit filter tabs work per page (new)	Pre-existing behaviour; recommend server-side filtering later	Noted
QA-23	INFO	Page versions cannot be deleted (new)	QA-TEST versions remain unpublished in Contact history; accept or add pruning later	Noted

05 HIGH DEFECTS: FINDING, FIX, RETEST

QA-01 Admin role could escalate to SuperAdmin

FIXED

FINDING

Holding `identity.users.manage` (the Admin role) allowed creating SuperAdmin accounts, granting SuperAdmin, resetting the SuperAdmin's password and deactivating them.

FIX

- New `IdentityAccessGuard`, used by create-user, assign and remove role, set active, reset password, delete user and set role permissions.
- Only a SuperAdmin can grant SuperAdmin or change a SuperAdmin account. Other users can grant only roles and permissions they already hold, and can manage only users whose access is a subset of their own.
- Nobody can deactivate, delete or change the roles of their own account. The last active SuperAdmin cannot be deactivated, deleted or demoted.
- Errors map to 403 (not allowed) and 409 (conflict), and every change is audited.

RETEST

A real Admin-role account attempted each attack through the API:

ATTEMPT BY ADMIN	RESULT	
Create a user with the SuperAdmin role	403 "Only a SuperAdmin can grant the SuperAdmin role."	PASS
Grant SuperAdmin to themselves / to another user	Refused (409 self / 403 other)	PASS
Reset the SuperAdmin's password	403	PASS
Deactivate / delete the SuperAdmin	403 / 403	PASS
Create an Editor (within own access)	201, still allowed	PASS
SuperAdmin deactivates own account	409 "You can't deactivate your own account."	PASS

QA-02 Uploads could be served as active content

FIXED

FINDING

Any file type was accepted; `.html` and `.svg` files with script were served as `text/html` and `image/svg+xml` on the website's domain.

FIX

- Uploads are identified by their contents, never the name or declared type. Only JPEG, PNG, GIF, WebP, AVIF and PDF up to 15 MB are accepted, and each is stored under the extension of its real type.
- The API's `/uploads` handler serves only those types, with a sandbox CSP.
- The website's `/uploads` route passes through only those types and adds the same sandbox.
- The admin file picker is limited to those types and shows the API's error message.

RETEST

HTML, SVG, EXE and script-disguised-as-PNG uploads: all 400 "Unsupported file type". A PNG renamed `.jpg` is stored as `.png`. Files over 15 MB are rejected. A valid PNG is served as `image/png` with a sandbox CSP. A non-media path on `/uploads` returns 404. The UI shows a clear refusal message. Six unit tests cover type detection.

QA-03 Staging noindex ineffective in container deployment

FIXED

FINDING

The Node adapter builds the request URL from `ORIGIN`, so the staging/production check always matched, and staging copies were indexable.

FIX

The hooks file now decides indexability from the host the visitor actually requested (`X-Forwarded-Host` or `Host`). The result goes in `locals.indexable`, which robots.txt, every page's robots meta tag and the `X-Robots-Tag` header all read. `docker-compose.yml` now takes the deployment address (`APP_URL` → ORIGIN) separately from the production site URL (`SITE_URL`).

SCENARIO (RETEST)	ROBOTS.TXT	META / HEADER	CONTACT FORM	
A. Production	Allow + sitemap	index / -	Works	PASS
B. Staging (APP_URL = staging)	Disallow: /	noindex / noindex	Works	PASS
C. Staging host on a production-configured container	Disallow: /	noindex / noindex	403 (misconfiguration, documented)	PASS
D. Bare IP address	Disallow: /	noindex / noindex	Works	PASS
E. Canonical links on staging	Point to https://www.summit-is.com.au/...			PASS

06 MEDIUM DEFECTS: FINDING, FIX, RETEST

QA-04 Login throttling

FIXED

FIX

The "auth" limiter is now partitioned by client IP. The frontend forwards the visitor IP on every API call (`handleFetch`), and the API trusts it only from private networks. A new `LoginThrottle` locks an email address for 15 minutes after 5 failures in 15 minutes. It applies to unknown emails too, so it reveals nothing about which accounts exist.

RETEST

Five failures return 401, then 429 "Too many failed sign-in attempts. Try again in 15 minutes." Another account still signs in. One IP is throttled on its 11th request in a minute, while a second IP still gets 200. Four unit tests cover the lockout.

QA-05 Password policy

FIXED

FIX

`PasswordPolicy` enforces 12–128 characters, rejects common or very low-variety passwords and passwords containing the email name, on both create and reset. The admin forms show the rule and enforce `minlength="12"`, and the generator now makes 16-character passwords.

RETEST

"a", "password1234", "aaaaaaaaaaaa" and a password containing the email name are all rejected with 400, and so is a short password on reset. The admin form blocks under-12 entries. Twelve unit tests cover the policy.

QA-06 Contact page title

FIXED

FIX

The root layout no longer emits a fallback `<title>`. Public pages get theirs from SeoHead; admin, login and error pages set their own.

RETEST

The raw server-rendered HTML of all 10 page types contains exactly one `<title>`, and it is the page's own. `/contact` shows "Contact Us | Summit Industrial Services, Karratha WA".

QA-07 Security headers

FIXED

FIX

- **Content Security Policy:** scripts limited to the site itself plus a per-request nonce (including the theme bootstrap script); styles allow Google Fonts; fonts, images and frames restricted to Google Maps; `object-src 'none'`, `frame-ancestors 'none'`, `form-action 'self'`.
- **Other headers on every response:** X-Frame-Options DENY, nosniff, Referrer-Policy, Permissions-Policy, Cross-Origin-Opener-Policy, and HSTS over HTTPS.
- **API:** nosniff, DENY and no-referrer; the `Server` header removed.

RETEST

Headers present. Framing the admin login from another origin fails to render. CSP violations: 0 across public and admin pages; fonts, the map and the theme script all work. An eval-based test helper was itself blocked by the CSP, which independently confirms it is enforced.

QA-08 Audit trail coverage

FIXED

FIX

Identity endpoints write audit events for: user created, activated, deactivated, deleted and password reset; role assigned or removed; role created, permissions changed and deleted; and sign-in success, failure and lockout. A reusable `.WithAudit()` filter covers the 14 hand-written endpoints (work-scope gallery, facts, narrative and quote; industry links; media alt text; enquiry status and assignment). The client IP is resolved through the trusted forwarded-headers middleware, and the admin audit log has a new **Security** tab.

RETEST — All 11 event types were found in the audit log after the API run. Failed sign-ins carry the visitor IP (198.51.100.x / 203.0.113.x), not the proxy's. User and role changes made in the admin UI appear in the log.

QA-09 CSV formula injection — FIXED

RETEST — An enquiry submitted through the website with the name `=HYPERLINK("https://example.com","QA-TEST")` is exported as `'=HYPERLINK(…)`, prefixed with a quote, so it opens as plain text in Excel.

QA-10 Server errors on invalid input — FIXED

FIX — A global `ApiExceptionHandler` returns 400 for malformed or incomplete requests and database constraint failures, 409 for duplicates, and a generic 500 with no internals for anything else (details are logged only). Blog posts and work scopes get field validation (required fields, lengths, slug format) with readable messages.

RETEST — Empty blog body: 400 (was 500). Invalid slug: 400 with a field message. Empty work scope: 400. Generic CRUD with missing fields: 400. Eleven unit tests cover the validation.

07 LOW AND INFO: FIX AND RETEST

ID	FIX	RETEST EVIDENCE	
QA-11	The API checks the account is active on every authenticated request (15 s cache, cleared immediately on change). Sessions are revoked on deactivate, delete and password reset.	Token rejected (401) immediately after deactivation; after a reset the old password fails and the new one works	PASS
QA-12	External media must be an absolute `https://` URL (API and form pattern)	`javascript:`, `http:` and `data:` rejected (400); https accepted; 7 unit tests	PASS
QA-13	Delete user and delete custom role (API and admin UI, with confirmation). Built-in roles and roles still assigned are protected.	UI create/delete of a user and a role passed; deleting a built-in role → 409; deleting an assigned role → 409; all QA accounts removed through the app	PASS
QA-14	Admin colour tokens: faint text `#8D93A0`, strong accent `#3F5BD8`, accent text `#8AA2FF`. Audit rows have a labelled toggle button with `aria-expanded`. The login error has `role="alert"`.	axe: 0 violations on all 14 screens (was 176 nodes); keyboard expansion of audit rows works	PASS
QA-15	Microsoft.AspNetCore.OpenApi 10.0.0 → 10.0.11 (Microsoft.OpenApi 2.7.5)	`dotnet list package --vulnerable`: none; `npm audit --omit=dev`: 0	PASS
QA-16	Unused code removed; page data made reactive; unused CSS removed; JSON-LD lint documented; Prettier applied	ESLint 0 · svelte-check 0 errors / 0 warnings · Prettier clean	PASS
QA-17	Enquiry alert email queued and sent by a background worker	Website enquiry answered in 158 ms (was ~7.5 s); alert email delivered about 5 s later	PASS
QA-18	Admin navigation, headings, buttons, dashboard and permission group renamed "Work scopes"	Admin screen heading and sidebar read "Work scopes"	PASS
QA-19	Theme-aware `--gold-on-ink` for the page-transition subline	axe in the dark theme: 0 violations (was 20)	PASS
QA-20	Forwarded headers trusted only from loopback and private networks; rate limits and audit log use the resolved IP	Per-IP limits behave independently per visitor; audit records visitor IPs	PASS
QA-21	Versions API returns title and changed fields; history screen has Title and Changes columns	History shows "Title" for the edited version and "First version" for #1	PASS

08 DETAILED RETEST RESULTS

8.1 API retest (110 cases, 110 passed)

AREA	CASES	HIGHLIGHTS	
Authentication and session	24	Generic errors; tamper and alg=none rejected; 30-minute tokens; refresh rotation and logout; lockout after 5; per-IP limit; password policy ×5; revocation on deactivate and reset	PASS
Authorisation and privilege	17	Anonymous rejected on 13 endpoints; limited-role matrix; 6 Admin escalation attempts refused; Admin can still create an Editor; self and last-SuperAdmin protection; built-in roles protected	PASS
Admin endpoints	14	All 13 endpoint groups return 200 for SuperAdmin; CSV export	PASS
Admin CRUD and deletion	11	Blog draft, publish, edit, delete; drafts hidden; assigned role cannot be deleted; custom role and QA users deleted	PASS
Validation	8	Empty, malformed and invalid-slug payloads return 400 (no 500s); duplicate slug 409; public contact validation	PASS
Injection and robustness	9	SQL-injection probes harmless; slug injection 404; page size capped at 200	PASS
XSS	1	Script in a post title or body is escaped on the published page	PASS
Media	13	Allowlist by content; real-type storage; 15 MB limit; empty file; https-only external media; sandboxed serving	PASS
Platform	2	API security headers and hidden Server header; /uploads refuses non-media types	PASS
Audit trail	11	User created, activated, deactivated, password reset, deleted; role created, permissions changed, deleted; sign-in success, failure, lockout; real client IP	PASS

8.2 Admin UI retest (46 cases, 46 passed)

GROUP	CASES	HIGHLIGHTS	
Access control and clickjacking	3	14 screens redirect anonymous visitors; CSV export blocked; admin cannot be framed	PASS
Login and session	6	Labelled fields; error announced (role=alert); HttpOnly / SameSite=Lax / Secure cookies; logout	PASS
Screens (1440 px) and responsive (390 px)	17	14 screens: 200, heading, 0 console errors, 0 failed requests; axe 0; no sideways scroll on mobile; "Work scopes" labels	PASS
Pages workflow	4	Edit live immediately; history shows titles and changes; rollback restores; raw title correct	PASS
Media workflow	3	Upload; delete with confirmation; disguised script refused with message	PASS
Enquiries workflow	4	Listed; status change; CSV export; formula escaped	PASS
Users and roles workflow	6	Password rule in form; create/delete user; create/delete custom role; built-in roles have no delete	PASS

GROUP	CASES	HIGHLIGHTS	
Audit log	3	Security tab; UI changes recorded; keyboard row expansion	PASS

8.3 Public website regression (36 cases, 36 passed)

TEST	RESULT	
WCAG 2.2 AA, light and dark themes, 11 pages × 2 widths (settled)	0 violations / 0 violations	PASS
Layout at 360 / 390 / 768 / 1440 px	0 overflow, 0 clipped headings	PASS
Touch targets, keyboard focus, mobile menu, reduced motion	All pass	PASS
Links (20), tel/mailto/maps, filters ×2, FAQ, next/previous	0 broken; filters announce state	PASS
404 for page / work scope / article; console and network	404 ×3; 0 errors, 0 failed requests	PASS
Contact form: pending state, validation, lost connection	All pass	PASS
Enquiry response time; background email delivered	158 ms; delivered to inbox	PASS
Per-visitor contact limit (5 per 10 min)	6th request 429; other visitor unaffected	PASS
One <title> per page and correct (10 pages)	All correct, including /contact	PASS
Indexing scenarios A–D (section 05)	All correct	PASS
Performance (throttled mobile): Home / Capabilities / Contact	LCP 1.15 / 0.84 / 0.76 s; CLS 0	PASS
CSP and security headers	Present; 0 violations; fonts, map and theme script work	PASS

8.4 Code and dependencies (8 cases, 8 passed)

CHECK	RESULT	
Backend unit tests	61 / 61 (password policy, lockout, file types, URLs, validation, plus the original 7)	PASS
Backend build	Succeeded, no compiler warnings in changed code	PASS
svelte-check	0 errors, 0 warnings	PASS
ESLint	0 problems	PASS
Prettier	All files formatted	PASS
npm runtime dependencies	0 vulnerabilities	PASS
NuGet dependencies (including transitive)	0 vulnerable packages	PASS
JSON-LD output escaping	`<` escaped; no raw closing tag	PASS

09 CLIENT DELIVERABLES, TEST DATA AND DEPLOYMENT NOTES

Client-facing response report (SIS-WEB-RR-01)

v1.0 noted that two statements in the response report were not yet true. Both are now accurate:

ITEM	STATEMENT	STATUS AFTER FIXES
P1-06	Staging and other hosts return `Disallow /` and `noindex`	**Now true** for the container deployment (QA-03 scenarios B–D)
P2-02	Contact title "Contact Us | Summit Industrial Services, Karratha WA"	**Now true** in the raw HTML as well (QA-06)

Test data

ITEM	STATUS
QA users and roles from v1.0 and v1.1 (all `qa-test-…`, `QA-TEST-ROLE-…`)	**Deleted** through the new delete functions; only the real admin and the 4 built-in roles remain
QA media and blog posts	**Deleted**
Contact page: unpublished QA-TEST versions in history	Remain in history (QA-23); the original version is live and verified
7 enquiries named "QA Test" / `=HYPERLINK…`	Remain; archive in Admin → Contact leads (no delete function, by design)
Audit-log entries from testing	Remain, by design

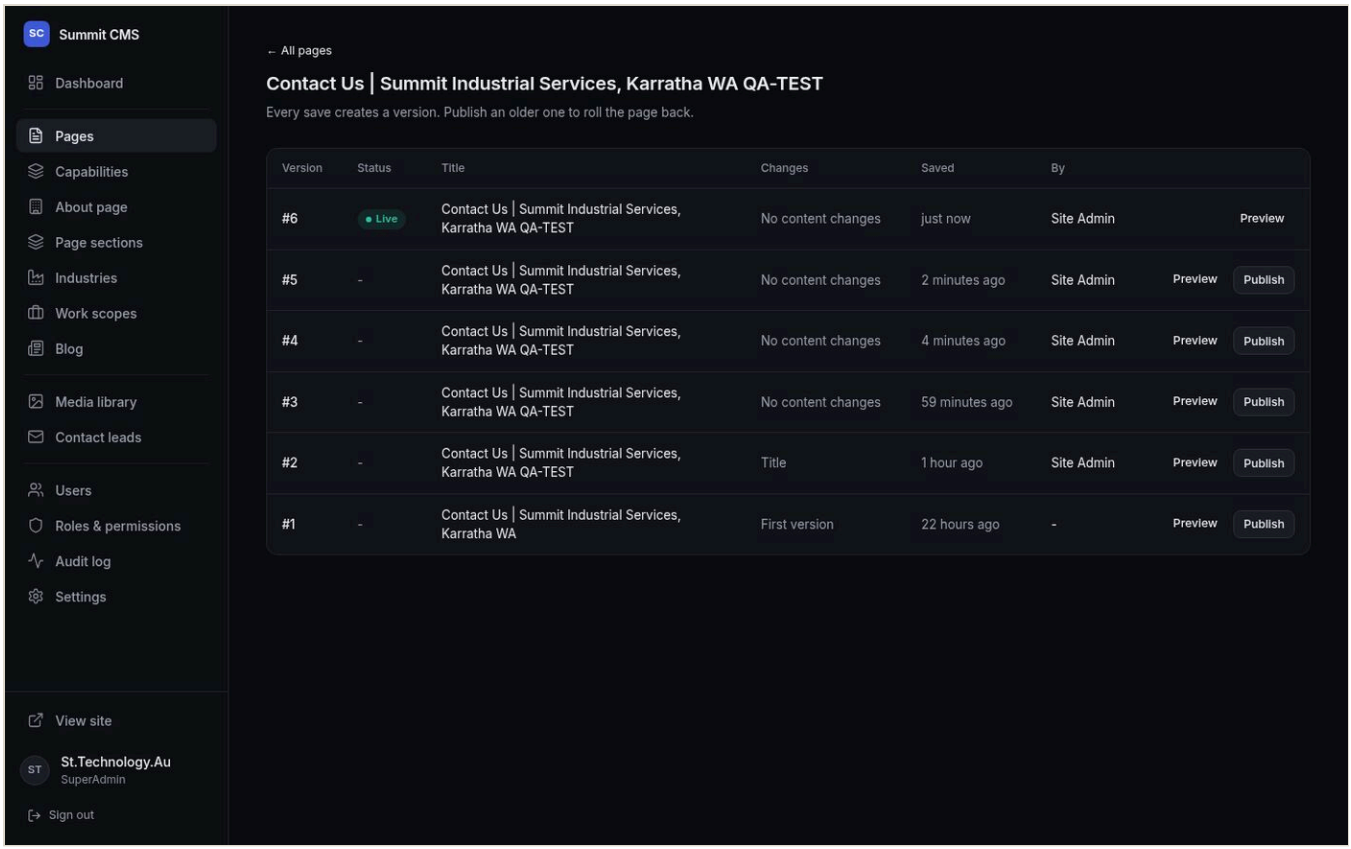
Deployment notes (changed by this release)

- **Production:** set `SITE_URL` and `APP_URL` to `https://www.summit-is.com.au`. Both default to it if omitted.
- **Staging:** keep `SITE_URL` as the production domain and set `APP_URL` to the staging address. Staging is then automatically noindex, with canonical links pointing to production.
- The API must stay on the private network, as in `docker-compose.yml`, so its trust in forwarded IP headers holds.
- **Security headers:** the site sends HSTS only over HTTPS, so make sure the proxy passes `X-Forwarded-Proto` (Coolify does by default).
- Admin passwords created before this release are not affected until changed. All new and reset passwords must meet the 12-character policy.

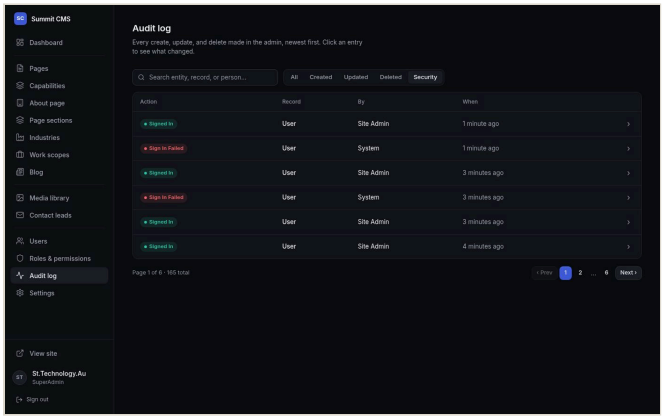
Remaining non-QA launch items

- Business-owner sign-off of content, imagery and articles (response report P0-04).
- Production domain, DNS, HTTPS, analytics, database backups and monitoring.
- A Summit-owned sending mailbox for enquiry alerts.
- A short check on a physical iPhone and Android device, and a basic screen-reader pass.
- Commit and deploy this release candidate; re-run the smoke checks on the live domain.

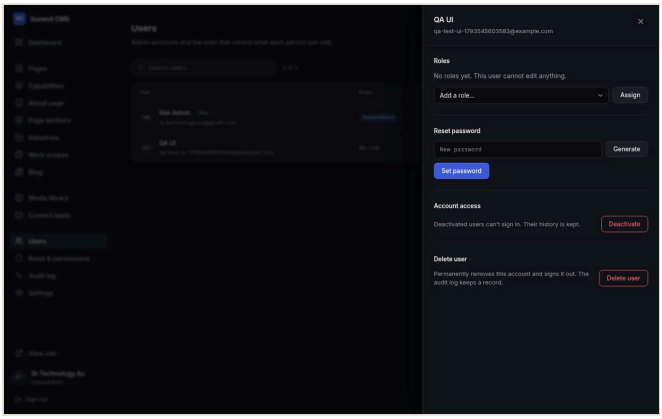
10 EVIDENCE: SCREENSHOTS



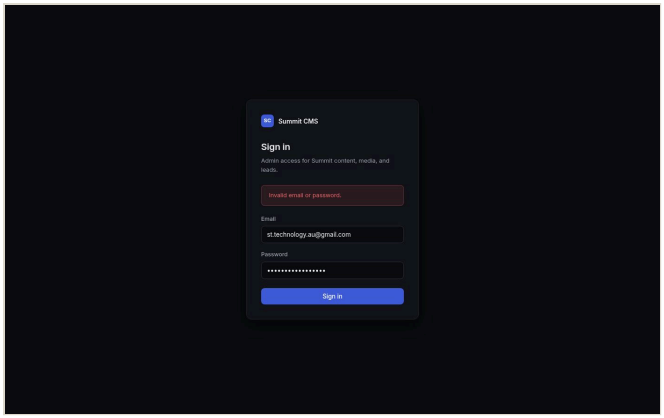
Page history (QA-21). Title and Changes columns. Captured mid-test while the QA-TEST edit (#6) was live, before it was rolled back to #1 (verified).



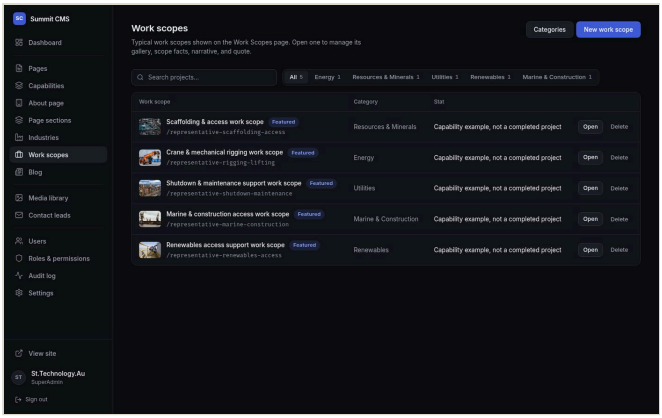
Audit log, Security tab (QA-08). Sign-ins and failed sign-ins recorded, with the new action labels.



User management (QA-13, QA-05). New "Delete user" section with confirmation, and the 12-character password rule.



Login error (QA-14). Announced to screen readers; strong-accent button meets contrast.



Work scopes (QA-18). Admin now uses the client-approved name.

11 DOCUMENT HISTORY

VERSION	DATE	CHANGE
1.0	1 Nov 2026	Initial QA cycle: 144 cases, 128 passed; 21 findings (3 High, 7 Medium, 7 Low, 4 Info); release not recommended.
1.1	1 Nov 2026	Retest after fixes: 200 cases (144 original + 56 regression), 200 passed; all 21 findings closed; QA-08 scope corrected; QA-22 and QA-23 added as information; release recommended from a QA standpoint.

ADDENDUM · VERSION 1.2 · 2 NOVEMBER 2026

12 MANUAL ADMIN UI PASS

After v1.1, the client reported that a hero image set on the About page did not appear on the site. The automated suites had checked that each admin form saved, but not that every saved field shows on the public site. We therefore ran a second, manual pass through the admin UI in Google Chrome. It covered all 15 admin areas, and for each change we checked the result on the public page.

15 / 15	16	15	1
Admin areas exercised by hand	New findings (QA-24 to QA-39)	Fixed and re-verified in Chrome	Open, owner action (QA-39)

Release status. The v1.1 recommendation stands. All 16 findings from this pass are fixed and re-verified, except QA-39 (the seeded administrator password), which only the site owner can change. Static checks (svelte-check, ESLint, Prettier) and the .NET build are clean on the build used for this retest.

Areas covered

ADMIN AREA	WHAT WAS EXERCISED (EACH CHANGE CHECKED ON THE PUBLIC SITE)	RESULT
Dashboard	Lead counts follow status changes; recent-activity feed; trend chart	PASS
Pages	Edit heading, subheading and SEO text; Home hero and secondary image; version history, preview and rollback	PASS
Capabilities	Create (with validation), edit, hide, delete	PASS
About page	Story, milestones, values, team photo set and clear, office, awards	PASS
Page sections	Create a section and items on each page and category slot; delete	PASS
Industries	Edit; link and unlink work scopes	PASS
Work scopes	Details, gallery, scope facts, narrative, pull quote (shown in home testimonials)	PASS
Blog	Draft hidden from site; publish visible; byline and structured data; delete	PASS
Media library	Upload, alt-text edit, delete (file removed from disk), stable ordering	PASS
Contact leads	Status, assign, resolve, tabs, search, reply e-mail and phone links	PASS
Users / Roles	Lists, role permissions load (security cases were covered in v1.1)	PASS
Audit log	Every action above recorded; before/after field view	PASS
Settings	Company phone shown across the site, metric stats, enquiry types (hide), footer text	PASS
View site	Opens the public site in a new tab	PASS

13 FINDINGS AND FIXES

ID	SEVERITY	FINDING	FIX AND RE-VERIFICATION	STATUS
QA-24	HIGH	Public pages crashed in the browser when the CMS held two list entries with the same text (reproduced: a second "2026" milestone broke the About page with a duplicate-key error).	34 content-keyed lists across 12 public pages and components are now keyed by position. Re-verified: a duplicate milestone renders twice with no console errors on all 7 public pages. Test entry deleted.	FIXED
QA-25	MEDIUM	Hero and secondary image pickers appeared for every page, but only the Home page displays them (the client's About-page report).	Image pickers are shown only for Home; other pages keep their stored values untouched. Intro text explains this. Re-verified in the edit drawers.	FIXED
QA-26	MEDIUM	Work-scope gallery offered a "Hero" image role that no page displays.	Role list is now "Full-width break image" and "Gallery pair" (default), with matching help text.	FIXED
QA-27	MEDIUM	Audit-log "before" values for generic records (milestones, capabilities, etc.) were stored double-encoded and showed as one escaped string.	Values already serialised are stored as-is. Re-verified: a deleted milestone shows Year, Title, Body as separate fields.	FIXED
QA-28	MEDIUM	Media library order changed on every load (seeded images share a timestamp), which led to editing the wrong image.	Ordered by date, then file name, then ID. Re-verified: identical order across reloads.	FIXED
QA-29	MEDIUM	Settings "footer text" was saved but never shown on the site.	Footer uses it (falls back to © year and company) followed by the ABN.	FIXED
QA-30	MEDIUM	Contact page FAQ could pick up the wrong section when several FAQ-layout sections existed.	The section in the "faq" slot is used first. Re-verified: 9 FAQ rows render.	FIXED
QA-31	MEDIUM	Contact-form error messages showed a hard-coded phone number, not the one in Settings.	Error and rate-limit messages read the phone and e-mail from Settings.	FIXED
QA-32	LOW	Page sections: category slots for Work Scopes and Insights were a hard-coded list; after saving, the list stayed on the previous page tab.	Slots are built from the live industry and blog categories; saving switches to the section's page. Re-verified with a temporary Insights section (deleted).	FIXED
QA-33	LOW	Pages list order varied; history preview showed no images.	Fixed menu order (Home → Contact); Home preview shows the hero and secondary image of that version.	FIXED
QA-34	LOW	Internal setting `content_revision` was listed (and editable) in Settings.	Hidden from the list and reserved against creation.	FIXED
QA-35	LOW	Lead reply subject read "general enquiry enquiry"; phone links kept spaces.	Subject now "Re: your general enquiry"; `tel:` links are digits only.	FIXED
QA-36	LOW	Blog: new posts had no default author; the company byline was marked up as a Person in search data.	Author defaults to the company; byline separator only shows with a role; company author is an Organization.	FIXED
QA-37	LOW	Dashboard activity showed raw codes (e.g. entity class names).	Plain labels ("Created · Milestone").	FIXED

ID	SEVERITY	FINDING	FIX AND RE-VERIFICATION	STATUS
QA-38	INFO	Admin wording still said "project" / "case study" in places, and some placeholders came from a US template.	Wording now "work scope" throughout; placeholders use Pilbara examples; the Settings enquiry-type hint matches the form label.	FIXED
QA-39	MEDIUM	The seeded SuperAdmin password is shorter than the 12-character policy (the policy applies to new passwords only).	**Owner action:** change the administrator password before go-live.	OPEN

Observations (no change made)

- Media width and height are not recorded on upload; images still render correctly, but recording them would avoid layout shift.
- The About page meta description is 194 characters (the admin counter flags it; recommended 120 to 160).
- Work-scope pull quotes appear in the Home "Client voice" area; quotes should be genuine client statements or reworded so they do not read as testimonials.
- QA-22 (audit-log filters apply per page) remains as noted in v1.1.

Test data

All records created for this pass (duplicate milestone, temporary page section, test blog post, test media upload, test capability) were deleted through the admin UI. Image alt text changed during testing was restored and checked.

Document history

VERSION	DATE	CHANGE
1.0	1 Nov 2026	Initial QA cycle.
1.1	1 Nov 2026	Retest after fixes; 200/200 pass.
1.2	2 Nov 2026	Addendum: manual admin UI pass in Chrome; QA-24 to QA-39 logged, QA-24 to QA-38 fixed and re-verified.